



CLOUDNOVA SOLUTIONS

Solutions for Tomorrow

RANSOMWARE INCIDENT RESPONSE PLAYBOOK

Initial – v1.0 – April 2026

DarkCipher RaaS Attack – CloudNova IaaS Platform – Dual Data Centre Scope

Document ID	CNS-IR-PB-001
Version	V1.0 – initial release
Classification	CONFIDENTIAL
Document Owner	Chief Information Security Officer (CISO)
Approval Date	April 25, 2026
Review Cycle	Quarterly Immediate update after any Critical-severity incident
Framework Alignment	NIST SP 800-61r3 CISA 2024 ISO/IEC 27035 SANS PICERL MITRE ATT&CK v15



Contents

PART I: Governance and Administration	4
1.0 Document Control.....	4
1.1 Approval and Sign-Off.....	4
2.0 Executive Summary	5
3.0 Purpose, Scope and Objectives	5
3.1 Purpose	5
3.2 Scope	6
3.3 Objectives	6
PART II: Key Facts, Threat Profile and Classification	6
4.0 Identification of Key Facts.....	6
4.1 Incident Overview	7
4.2 Attack Timeline	7
5.0 Threat Actor Profile — DarkCipher	8
5.1 MITRE ATT&CK v15 Technique Mapping	8
5.2 Key Scenario Implications	9
6.0 Incident Classification and Severity Matrix.....	9
6.1 Severity Definitions and Response Parameters	9
6.2 Escalation Decision Tree	11
PART III: Incident Response Procedures	12
7.0 Preparation.....	12
7.1 Pre-Incident Readiness Requirements.....	12
7.2 Tabletop Exercise Template.....	12
8.0 Detection and Identification	13
8.1 Detection Sources.....	13
8.2 Indicators of Compromise	13
8.3 Validation and Incident Confirmation.....	14
9.0 Triage	15
9.1 First 15 Minutes Checklist	15
9.2 First 60 Minutes Checklist	15
10.0 Containment Procedures	16
10.1 Short-Term Containment Checklist — 0 to 6 Hours.....	16
10.2 Long-Term Containment Checklist — 6 to 48 Hours	16
11.0 Eradication	17



11.1 Eradication Checklist.....	17
12.0 Recovery	18
12.1 Recovery Validation Criteria.....	18
12.2 Recovery Checklist	18
12.3 Ransom Payment Decision Framework	19
13.0 Post-Incident Activities.....	20
13.1 Post-Incident Checklist.....	20
13.2 Lessons Learned Template.....	20
13.3 Improvement Recommendations from April 2026 Incident	21
14.0 Roles and Responsibilities.....	21
14.1 IR Team Structure and Authority.....	21
14.2 RACI Matrix	22
14.3 Role Definitions	23
15.0 Communication Plan.....	23
15.1 Communication Chain.....	23
15.2 Communication Templates.....	24
PART V: Evidence, Compliance and Metrics.....	26
16.0 Evidence Handling and Forensics	26
16.1 Collection Standards.....	26
16.2 Chain of Custody Register	27
18.0 Metrics and Reporting.....	28
PART VI: Appendices.....	29
Appendix A: Tool Reference.....	29
Appendix B: Contact List	29
Appendix C: Command Reference	30
Windows Incident Response Commands.....	30
Linux Incident Response Commands.....	30
Appendix D: Glossary.....	30



PART I: Governance and Administration

1.0 Document Control

This is a controlled document. Every revision requires formal approval before distribution. The version number on the cover supersedes all prior editions. Unauthorised modifications are prohibited.

Field	Detail
Document Title	Ransomware Incident Response Playbook – Initial release
Document ID	CNS-IR-PB-001
Version	V1.0 –
Author / Owner	CISO, CloudNova Solutions
Approved By	CISO and CloudNova Executive Leadership Team
Approval Date	April 25, 2026
Next Review Date	July 25, 2026 (Quarterly cycle) or immediately after any Critical incident
Classification	CONFIDENTIAL – TLP: RED. Distribution restricted to CloudNova IR Team members and authorised external partners. Not for public release.
Regulatory Basis	NIST SP 800-61r3 NIST CSF 2.0 CISA Federal Playbooks (2024) ISO/IEC 27035:2023 GDPR/applicable data law

Table 1 – Document Information 1

1.1 Approval and Sign-Off

Name / Title	Role	Signature	Date
[CISO Name]	Document Owner / Approver	_____	25 Apr 2026
[CEO / MD Name]	Executive Sponsor	_____	25 Apr 2026
[Legal Counsel Name]	Legal Reviewer	_____	25 Apr 2026

Table 2 – Approval and Sign-Off Register 1



2.0 Executive Summary

This playbook defines CloudNova Solutions' response to ransomware attacks across its dual-data-centre IaaS platform. It was developed in direct response to the April 2026 DarkCipher incident, in which ransomware-as-a-service affiliates exploited an unpatched third-party monitoring tool to encrypt virtual machines across both facilities, disrupting services for more than 70 client organisations simultaneously.

The document covers every stage of the incident lifecycle: preparation through post-incident improvement. It aligns to NIST SP 800-61 Revision 3 (aligned with NIST CSF 2.0), the CISA Federal Cybersecurity Incident and Vulnerability Response Playbooks (2024), ISO/IEC 27035:2023, and the MITRE ATT&CK framework. It applies to all ransomware variants: encryption-only, double extortion, RaaS-delivered, and ransomware deployed via phishing or supply chain compromise.

The core principle of this playbook is that a multi-tenant IaaS provider cannot treat a ransomware event as an internal IT problem. When encryption spreads across shared virtual infrastructure, the incident immediately becomes a client-continuity crisis, a regulatory notification event, and a reputational risk simultaneously. This document addresses all three tracks in parallel.

Impact Area	Without This Playbook	With This Playbook
Client Downtime	Days to weeks; no prioritisation across 70+ tenants	48–72-hour prioritised recovery by SLA and business impact
Regulatory Risk	Missed statutory deadlines; regulatory investigation	Legal Counsel engaged within 30 minutes; deadlines tracked from declaration
Financial Exposure	Uncontrolled DFIR costs; SLA penalties; ransom paid without governance	Ransom decision framework; insurer notified within 24 hours; Board sign-off required
Reputational Risk	Uncoordinated communications amplify client panic and media exposure	Pre-approved templates deployed within 2 hours of incident confirmation

Table 3 – Business Impact Comparison: Wi 1

3.0 Purpose, Scope and Objectives

3.1 Purpose

This playbook exists to give CloudNova's Incident Response Team a pre-defined, tested framework for managing ransomware events. It eliminates improvisation during the highest-pressure moments of an incident, where ad hoc decisions routinely cost more time, money, and client trust than the attack itself. It also satisfies the governance requirement that CloudNova maintain documented, framework-aligned incident response procedures as expected by clients, auditors, and regulators.



3.2 Scope

Attribute	Detail
In Scope	Ransomware (RaaS, double extortion, encryption-only); malware delivered via phishing; lateral movement via unpatched third-party tools; multi-tenant IaaS VM encryption events; data exfiltration combined with encryption
Environment	CloudNova dual data centres; all VM hosts and hypervisors; IaaS management platform; client tenant environments; third-party monitoring tools deployed on virtual hosts
Out of Scope	Physical data centre access incidents; client-side endpoint security outside CloudNova managed scope; DDoS events; non-ransomware network intrusions (addressed in separate playbooks)
Related Documents	CloudNova Business Continuity Plan (BCP); Data Breach Response Policy; Patch Management Standard; Acceptable Use Policy; Vendor Risk Management Policy

Table 4 – Playbook Scope Definition 1

3.3 Objectives

- Contain active ransomware propagation across all VM hosts within 6 hours of incident declaration.
- Eradicate all malicious artefacts and close all exploited vulnerabilities before any system returns to production.
- Restore all 70+ affected client tenants within 72 hours, sequenced by contractual SLA priority.
- Notify all affected clients within 2 hours and regulatory bodies within applicable statutory deadlines.
- Preserve forensic evidence in a manner consistent with legal admissibility standards from the first moment of response.
- Complete a root cause analysis and binding corrective action plan within 5 business days of incident closure.

PART II: Key Facts, Threat Profile and Classification

4.0 Identification of Key Facts

This section documents the critical incident data extracted from the April 2026 DarkCipher event. Every field below carries direct operational weight for the response procedures in this playbook. The DarkCipher incident is not a generic ransomware scenario: its multi-tenant blast radius, supply chain entry point, and RaaS model distinguish it from a single-organisation attack and drive several departures from standard single-tenant IR playbook designs.



4.1 Incident Overview

Field	Detail
Organisation	CloudNova Solutions – IaaS provider for 150+ SMB clients across two data centres
Incident Type	Ransomware-as-a-Service attack: file encryption, extortion demand, probable prior data exfiltration
Threat Actor	DarkCipher – known RaaS affiliate group with documented prior victims and established extortion infrastructure
Detection Time	Monday, 07:30 a.m. local – detected reactively by system administrators. No automated alert fired.
Initial Access Vector	Spear-phishing email to a systems engineer containing a macro-enabled Excel document (.xlsm). Macro executed on document open.
Pivot Mechanism	Unpatched vulnerability in a third-party monitoring tool deployed across virtual hosts in both data centres. Used for privilege escalation and lateral movement.
Payload	Ransomware encrypting VM storage volumes across both data centres simultaneously
Ransom Note	Deployed to all administrator dashboards across the IaaS platform. Demand: 15 Bitcoin (BTC)
Clients Affected	70+ clients reporting access failure within 45 minutes of detonation
Infrastructure Impacted	VMs in both data centers; IaaS management platform; administrator dashboard system
IR Response Team	CISO, System Administrators, Legal Counsel, Customer Relations

Table 5 – Assumptions and Constraints 1

4.2 Attack Timeline

Time (Local)	Phase	Event
Pre-incident	Initial Access	Phishing email with macro-enabled .xlsm delivered to systems engineer. Macro executed on document open. C2 beacon established.
Pre-incident	Lateral Movement	Attacker exploited unpatched monitoring tool vulnerability. Moved laterally across VM hosts in both data centres. Reconnaissance and ransomware staging completed.
~07:15 Mon	Detonation	Ransomware payload activated. File encryption began across VM storage in both data centres. Client access failures commenced.
07:30 Mon	Detection	System administrators detected abnormal file encryption activity. Incident declared. No automated alert had triggered prior to this point.



~08:00 Mon	Client Impact	70+ clients reported inability to access cloud-hosted resources. Customer Relations activated.
~08:30 Mon	Ransom Delivery	DarkCipher ransom note appeared on all administrator dashboards. Demand: 15 BTC for decryption key.
~09:00 Mon	IR Activation	CISO convened full IR Team. This playbook formally activated. All four response roles engaged.

Table 6 – Incident Overview: April 2026 1

5.0 Threat Actor Profile — DarkCipher

Understanding DarkCipher's operating model is not background context. It directly shapes containment, eradication, and ransom decision procedures. Treating DarkCipher as a generic ransomware gang rather than a RaaS affiliate operation leads to response gaps.

Attribute	Detail
Threat Group	DarkCipher – Ransomware-as-a-Service affiliate group
Business Model	RaaS: DarkCipher leases ransomware infrastructure, tooling, and extortion support to affiliate operators who conduct the attacks. Ransom revenue is split between affiliate and developer.
Known TTPs	Phishing-to-macro delivery; exploitation of unpatched enterprise tools; hypervisor-level lateral movement; double extortion (exfiltrate then encrypt); ransom note deployment to management dashboards
Double Extortion Risk	DarkCipher affiliates routinely exfiltrate data before deploying encryption. Absence of confirmed exfiltration in initial incident data does NOT rule it out. Forensic egress analysis is mandatory.
Sanctions Risk	RaaS operators may be connected to sanctioned entities. Legal Counsel must conduct a sanctions screening before any ransom payment action is considered.
Known Decryptors	Check with law enforcement and security researchers for any publicly released DarkCipher decryptors before considering payment.

Table 9 – Attack Timeline Reconstruction 1

5.1 MITRE ATT&CK v15 Technique Mapping

Tactic	Technique	Observed at CloudNova
Initial Access	T1566.001 – Spear Phishing Attachment	Macro-enabled .xlsm delivered to systems engineer. Executed on document open.
Execution	T1204.002 – Malicious File	Macro execution delivered payload and established C2 beacon to attacker infrastructure.



Privilege Escalation / Lateral Movement	T1190 – Exploit Public-Facing Application	Unpatched third-party monitoring tool exploited for privilege escalation and lateral movement across all VM hosts in both data centres.
Lateral Movement	T1210 – Exploitation of Remote Services	Ransomware propagated across VM hosts using the monitoring tool as a pivot.
Exfiltration	T1041 – Exfiltration Over C2 Channel	Probable pre-encryption data exfiltration via C2 channel from monitoring tool hosts. Requires forensic confirmation.
Impact	T1486 – Data Encrypted for Impact	Files encrypted across VM storage volumes. Ransom note deployed to all administrator dashboards.

Table 8 – DarkCipher Threat Actor Profil 1

5.2 Key Scenario Implications

1. Several distinct factors that separate this scenario from an ordinary single-organisation ransomware situation include:
2. **Multi-tenancy problem:** VM isolation impacts 70+ tenants at once; hence, the issue requires a business decision, not a technical one. VMs should be isolated based on tenant SLA priority, rather than convenience.
3. **RaaS double extortion threat:** Since data exfiltration has occurred despite lacking early indication of it, forensic analysis of data exfiltration paths needs to be done alongside containment.
4. **Policy flaw:** Unpatched monitoring solution indicated governance weaknesses; the use of third-party software was overlooked by policies. It is vital for patching to encompass all third-party software.
5. **Excessive privilege problem:** Successful ransomware infection happened because of over-permissive privileges granted to the exploited account. Implementation of least privilege concept is crucial here.

6.0 Incident Classification and Severity Matrix

Severity must be assigned within 30 minutes of incident declaration and re-assessed as the picture evolves. The level assigned determines notification velocity, resource mobilisation, and decision authority.

6.1 Severity Definitions and Response Parameters

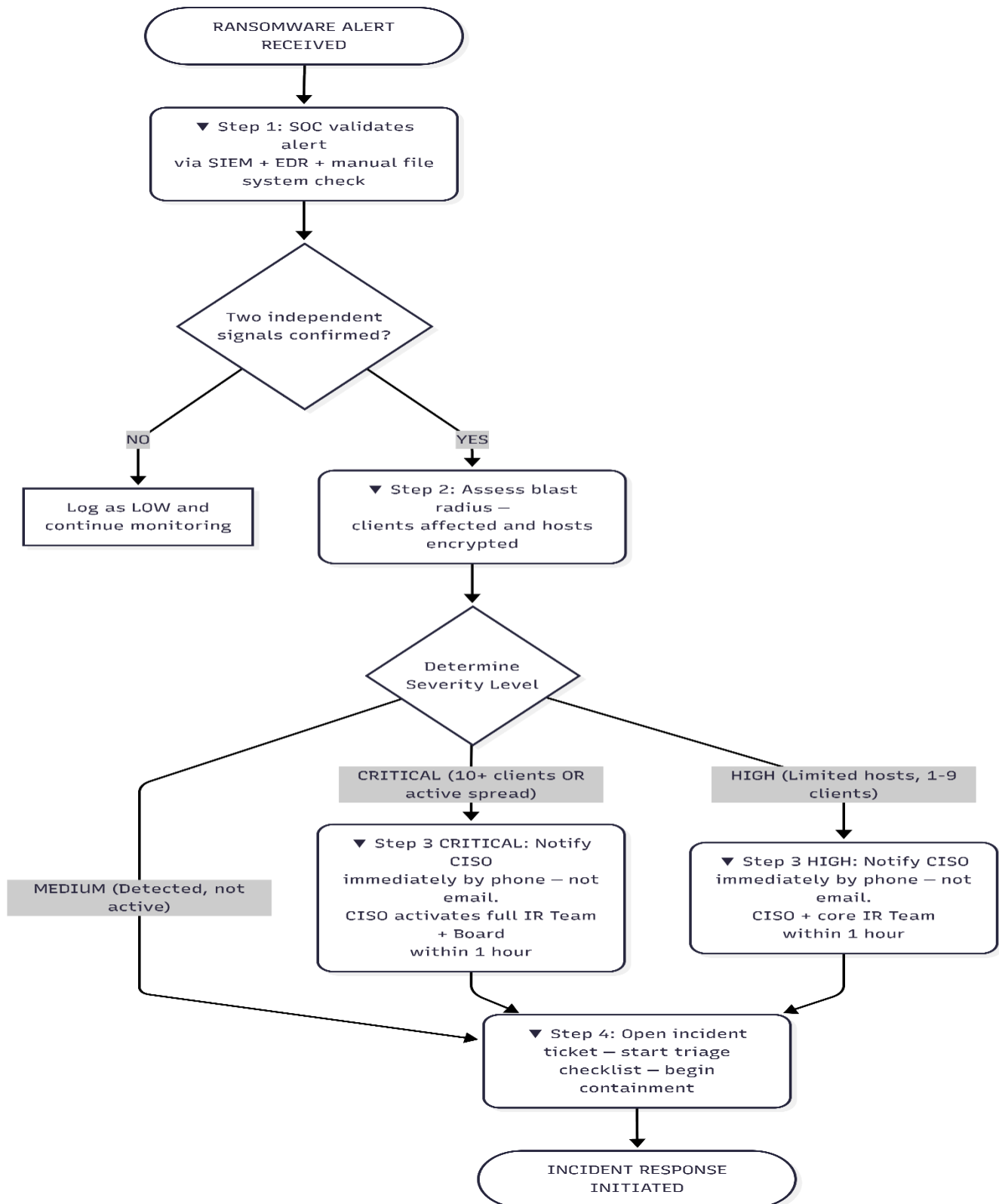


Level	Criteria	Response Time	Escalation	Business Impact
CRITICAL	Active encryption; 10+ clients disrupted; ransom deployed; confirmed or suspected exfiltration. The April 2026 DarkCipher event: Critical from 07:30 Monday.	IMMEDIATE	CISO + Board within 1 hour	Major revenue loss; widespread client downtime; regulatory breach probable; reputational risk
HIGH	Encryption on limited hosts; 1-9 clients disrupted; confirmed credential compromise; active lateral movement detected	Within 1 hour	CISO notified; exec within 2 hrs	Significant client impact; SLA breach likely; legal review required
MEDIUM	Malware detected but not executed; phishing compromise on non-privileged account; suspicious activity under investigation	Within 4 hours	IR Led notified; management aware	Limited impact; no confirmed client disruption; precautionary action required
LOW	Blocked phishing; benign signature detected; unconfirmed suspicious activity with no execution evidence	Within 24 hours	SOC handles; IR Lead informed	No confirmed business impact; monitor and document

Table 17 – Severity Classification Matrix 1



6.2 Escalation Decision Tree



escalation decision tree 1



PART III: Incident Response Procedures

Part III defines the operational response across all lifecycle phases. Procedures align to the NIST CSF 2.0 Respond and Recover functions and the CISA Federal Cybersecurity Incident Playbook (2024). Each phase must be executed in sequence. No phase is skipped or shortened based on perceived urgency.

PHASE 1: Preparation – Before the Incident

7.0 Preparation

Preparation is the only phase that happens before the incident starts. Everything else is reactive. The April 2026 DarkCipher event confirmed that reactive response without a pre-built framework costs more time, money, and client trust than any investment in preparation. The items below are standing requirements, not incident-triggered actions.

7.1 Pre-Incident Readiness Requirements

1. Keep an up-to-date list of all assets such as VM hosts, hypervisors, third-party applications, and client mappings; audit quarterly.
2. Install EDR with ransomware behavioural detection on all hosts; monitor using network-based methods where EDRs cannot be deployed.
3. Ensure compliance with patch management SLAs: Critical (24 hours), High (72 hours), Medium (30 days), and all third-party applications.
4. Store offline and immutable backups in a separate environment; validate restore process quarterly.
5. Adopt MFA policy across privileged users, administration consoles, and all remote access methods.
6. Have a DFIR retainer for immediate forensic assistance.
7. Have out-of-band communication lines for IR team coordination.
8. Hold annual ransomware table-top exercises and revise the plan according to results.

7.2 Tabletop Exercise Template

Exercise Element	Detail
Scenario	Replicate the DarkCipher attack: phishing delivery → monitoring tool exploitation → multi-tenant VM encryption → ransom demand
Objectives	Test severity classification speed; role activation clarity; containment decision authority; client communication timing; ransom payment decision governance
Participants	All four IR roles: CISO, System Admins, Legal Counsel, Customer Relations. Observe Board decision-making for ransom scenario.
Duration	3 to 4 hours. Include all phases: Detection through Post-Incident Review.



Evaluation Criteria	Time to severity classification; time to first VM isolation; time to client notification draft; ransom decision governance process; evidence preservation steps
Output	Written gap analysis. Binding corrective actions with owners and deadlines. Playbook update before next exercise.

Table 18 – Tabletop Exercise Template 1

PHASE 2: Detection and Analysis

8.0 Detection and Identification

Detection is where the April 2026 incident failed. Encryption had already spread across both data centres before a single automated alert fired. The detection posture below is designed to identify ransomware activity before it reaches client-impact scale. Every detection source below must be operational and tested before any incident occurs.

8.1 Detection Sources

Source	Mechanism	Target Alert
SIEM Platform	Log correlation: hypervisors, firewalls, DNS, proxy, email gateway, EDR	Mass file I/O; encryption pattern; shadow copy deletion; abnormal process chains
EDR / Endpoint Agent	Behavioural monitoring tuned for ransomware execution signatures on VM hosts	Rapid file modification; vssadmin.exe execution; unknown encryption process
IDS / IPS	Network traffic analysis for C2 signatures and lateral movement patterns	C2 beaconing; unusual east-west VM traffic; large unexpected outbound volumes
Email Gateway	Inbound attachment scanning for malicious macros and phishing indicators	Macro-enabled .xlsm; phishing domain; malicious embedded URL
DLP	Outbound data flow monitoring for volume anomalies and sensitive content	Large unexpected outbound transfer; client data exfiltration signature

Table 19 – Detection Sources and Target 1

8.2 Indicators of Compromise

IOC Type	Indicator	Context	Confidence
----------	-----------	---------	------------



File Activity	Mass file extension changes on VM storage volumes	Active ransomware encryption	HIGH
Email Artefact	Macro-enabled .xlsm from external sender to systems engineer	Confirmed phishing vector	HIGH
Process Activity	vssadmin.exe delete shadows; rapid file writes loops from unknown process	Shadow copy deletion; active encryption	HIGH
Network Traffic	Anomalous outbound from monitoring tool hosts to unknown IPs	C2 channel or data exfiltration	MEDIUM
Persistence	New startup registry entries; modified scheduled tasks	Attacker maintaining access	MEDIUM
Dashboard Artefact	Ransom notes on all administrator dashboards	DarkCipher attribution; encryption complete	HIGH

Table 20 – Indicators of Compromise (IOC 1)

8.3 Validation and Incident Confirmation

- Correlate SIEM alerts with EDR telemetry and network logs. Two or more independent signals = confirmed incident. Declare and act.
- Confirm mass file extension changes on VM storage. Sample affected files to verify active encryption.
- Identify active processes matching ransomware signatures: mass file writes, vssadmin deletion, unknown encryption binaries.
- Assess outbound traffic from monitoring tool hosts. Check destination IPs against known DarkCipher C2 infrastructure via threat intelligence.
- Map all affected VM hosts to client tenants across both data centres. This count drives severity classification.
- Declare incident, assign severity, open ticket, notify CISO by phone. Begin containment. Do not wait.



PHASE 3: Initial Response and Triage

9.0 Triage

9.1 First 15 Minutes Checklist

Time lost in the first 15 minutes directly determines how many additional hosts are encrypted. Begin immediately on alert receipt. Do not wait for full team assembly.

☐	Action	Owner	Time Target
☐	Validate alert: SIEM + EDR + manual file system check. Two independent signals required.	SOC Analyst	T+0 to T+5 min
☐	Confirm ransomware activity. Declare incident if confirmed.	SOC Analyst	T+5 to T+8 min
☐	Assign severity CRITICAL. Open incident ticket with timestamp, scope, and detection source.	SOC Analyst	T+8 to T+10 min
☐	Notify CISO by phone. Do not use corporate email. Use out-of-band channel.	SOC Analyst	T+10 min
☐	Begin VM isolation on confirmed affected hosts at hypervisor network level only.	System Admins	T+10 to T+15 min

Table 21 – First 15 Minutes Triage Check 1

9.2 First 60 Minutes Checklist

☐	Action	Owner	Time Target
☐	Collect initial logs from hypervisors, network devices, and email gateway before any remediation.	System Admins	T+15 to T+30 min
☐	Disable monitoring tool network access across all hosts in both data centers. Suspend all service accounts.	System Admins	T+20 to T+25 min
☐	Revoke compromised engineer credentials: AD account, VPN certificates, all API keys.	System Admins	T+20 min
☐	Block confirmed C2 IP addresses and domains at the perimeter firewall.	Network Admin	T+25 min
☐	Notify Customer Relations to prepare client notification. Await CISO sign-off before sending.	CISO	T+30 min
☐	Notify Legal Counsel. Begin notification obligation assessment and sanctions screening.	CISO	T+30 to T+45 min



☐	Complete scope: enumerate all affected VMs and map to client tenants across both data centers.	System Admins	T+30 to T+60 min
☐	Convene full IR Team briefing. Assign responsibilities. Confirm escalation paths.	CISO (chair)	T+60 min

Table 22 – First 60 Minutes Triage Check 1

PHASE 4: Containment

10.0 Containment Procedures

10.1 Short-Term Containment Checklist — 0 to 6 Hours

☐	Containment Action	Owner
☐	Isolate all confirmed compromised VMs at hypervisor network level. Guest OS controls are insufficient — attacker may have disabled them.	System Admins
☐	Keep affected VMs powered on were safe. Memory capture before shutdown preserves attacker artefacts and potential decryption key material.	System Admins
☐	Document every isolated VM: hostname, client tenant, isolation timestamp, administrator name. This log is forensic evidence.	System Admins
☐	Revoke all credentials for compromised engineer: Active Directory account, VPN, cloud console, all API keys.	System Admins
☐	Audit all privileged logins across both data centres for 72 hours prior. Suspend accounts with anomalous patterns.	System Admins
☐	Block all outbound internet traffic from affected data centre segments at the perimeter firewall.	Network Admin
☐	Add confirmed C2 IPs and domains to perimeter block lists and DNS blackholes from threat intelligence feeds.	Network Admin
☐	Preserve encrypted VM snapshots as forensic evidence. Do not restore or modify. Label and log in CoC Register.	System Admins

Table 23 – Short-Term Containment 1

10.2 Long-Term Containment Checklist — 6 to 48 Hours

☐	Action	Owner
☐	Implement micro-segmentation between client VM tenants using hypervisor-enforced network policies. Prevents cross-tenant spread.	Network Admin



☐	Build isolated recovery network from clean, unaffected backup infrastructure for staging restored VMs.	System Admins
☐	Conduct threat-hunting across all non-isolated VM hosts: look for dormant malware and attacker persistence mechanisms.	SOC Analyst
☐	Tune SIEM rules to DarkCipher TTPs. Deploy enhanced alerting on file I/O, outbound traffic, and process execution.	SOC Analyst
☐	Restrict all admin interface access to MFA-verified accounts only. Revoke all other active sessions.	System Admins
☐	Engage DFIR retainer partner if internal forensic capacity is insufficient to maintain investigation pace.	CISO

Table 24 – Long-Term Containment Checklist 1

PHASE 5: Eradication

11.0 Eradication

No system returns to production before this checklist is completed and the CISO provides written sign-off. Cleaning infected VM hosts in place is not permitted. Full rebuild from verified, hash-authenticated gold images are mandatory.

11.1 Eradication Checklist

☐	Eradication Action	Owner
☐	Document all ransomware artefacts: files, processes, registry keys, scheduled tasks, persistence mechanisms, attacker-created accounts.	System Admins
☐	Rebuild all confirmed compromised VM hosts from verified, hash-authenticated gold images predating the compromise window.	System Admins
☐	Patch or decommission the vulnerable monitoring tool. If no vendor patch exists, replace with a security-assessed alternative before any host returns to production.	System Admins
☐	Full vulnerability scan across all virtual infrastructure. Remediate all Critical and High findings before production reconnection.	System Admins
☐	Reset all service account passwords. Rotate all API keys and OAuth tokens for the monitoring tool and all related systems.	System Admins
☐	Block macro execution in all externally-received Office documents via group policy. Enforce organisation-wide.	System Admins
☐	Run secondary malware scan and full IOC sweep across every host. No host returns to production if any unresolved IOC remains.	SOC Analyst



☐	CISO provides written sign-off that eradication is complete. Recovery cannot begin before this is obtained.	CISO
--------------------------	---	------

PHASE 6: Recovery

12.0 Recovery

12.1 Recovery Validation Criteria

Recovery is not declared complete until every criterion below is independently verified. The CISO formally closes the incident only after all items are confirmed in writing.

Criterion	Verification Method	Verified By
No active IOC alerts for 24 hours post-reconnection	SIEM dashboard and EDR telemetry review. SOC written confirmation.	SOC Analyst
Exploited vulnerability patched and confirmed	Vulnerability scanner rescans; vendor patch confirmation documentation.	System Admins
All restored VMs pass integrity check	Malware scan: clean; OS binary SHA-256 hash verified against gold image baseline.	System Admins
All 70+ client tenants restored and individually confirmed	Customer Relations written confirmation from each client. Restoration notice issued per client.	Customer Relations
All compromised credentials rotated	Identity management audit; MFA confirmed active on all privileged accounts.	System Admins
Enhanced monitoring active for 72 hours post-full-recovery	SIEM enhanced rule set confirmed; EDR coverage verified on all restored hosts.	SOC Analyst

Table 25 – Recovery Validation Criteria 1

12.2 Recovery Checklist



☐	Recovery Action	Owner
☐	SHA-256 verifies all backup files. Confirm backups predate the compromise window before restoration begins.	System Admins
☐	Restore core IaaS platform first. Then restore client tenants in priority order by SLA and assessed business impact.	System Admins / CISO
☐	Malware scan and vulnerability check on each restored VM before connecting to the production network.	SOC Analyst
☐	Reconnect VMs in phased batches with minimum 4-hour enhanced monitoring window between batches.	System Admins
☐	Notify each client individually when their tenant is restored. Issue written restoration confirmation per client.	Customer Relations
☐	Maintain enhanced SIEM and EDR monitoring for minimum 72 hours after full recovery.	SOC Analyst
☐	All validation criteria confirmed in writing. CISO formally declares the incident closed.	CISO

Table 26 – Recovery Checklist 1

12.3 Ransom Payment Decision Framework

The 15 BTC demand from DarkCipher requires a governed decision process. This sequence is mandatory. No payment action may be taken before all steps are completed.

1. Legal Counsel conducts a sanctions screening against DarkCipher affiliates. If the group is connected to a sanctioned entity, payment may constitute a legal violation regardless of business rationale.
2. CISO assesses backup availability: are clean, verified backups recoverable within 72 hours? If yes, payment is inadvisable and should not proceed without Board escalation.
3. CISO and Legal Counsel present options to the Board in writing, including estimated recovery timelines with and without payment, sanctions risk, insurance coverage, and law enforcement guidance.
4. Board provides written approval before any payment-related action is taken. Verbal approval is not sufficient.
5. Law enforcement is notified of the incident regardless of payment decision. Notification may provide access to government-held descriptors.

PHASE 7: Post-Incident Activities



13.0 Post-Incident Activities

13.1 Post-Incident Checklist

☐	Action	Deadline
☐	CISO formally declares incident closed and communicates to all IR Team members in writing.	Day 0
☐	Convene Lessons Learned meeting. All four IR Team roles must attend.	Within 5 business days
☐	Complete Root Cause Analysis document and distribute to IR Team.	Within 5 business days
☐	Produce full Incident Report (CONFIDENTIAL) including technical analysis, client impact, and evidence inventory.	Within 7 business days
☐	Submit Post-Incident Executive Report to Board including corrective action plan with owners and deadlines.	Within 10 business days
☐	Update this playbook based on PIR findings, new DarkCipher intelligence, and any framework updates.	Within 14 business days
☐	Commission external penetration test to validate all remediation actions.	Within 3 months
☐	Verify all corrective actions closed and signed off by CISO.	Per assigned deadlines

Table 27 – Post-Incident Activity Check

13.2 Lessons Learned Template

Field	Response
What happened?	[Factual chronological description from detection to closure]
What worked?	[Actions, tools, or behaviours that demonstrably limited impact]
What failed or was missing?	[Detection delays; missing controls; unclear roles; unavailable tools; communication failures]
Root Cause	[The systemic failure that enabled the incident. Distinguish from the trigger event.]
Preventive Actions	[Specific, measurable improvements with defined completion criteria and verification method]



Owner / Deadline	[Named individual accountable for delivery. Specific date. No open-ended deadlines.]
Verified Closed By	[CISO written confirmation with date that each action is implemented and validated]

Table 28 – Lessons Learned Template 1

13.3 Improvement Recommendations from April 2026 Incident

#	Root Cause	Lesson	Corrective Action	Owner
1	Unpatched third-party monitoring tool	Third-party software excluded from patch management scope enabled full lateral movement across both data centres	Expand patch scope to all third-party tools. Vendor security reviews at onboarding and annual intervals.	CISO / Admins
2	Privileged account phishing success	Systems engineer with hypervisor access opened malicious document, enabling the full attack chain	Quarterly phishing simulation. Block external-origin Office macros by policy.	CISO
3	No VM tenant micro-segmentation	Ransomware spread across all client tenants from a single compromise with no network boundary to slow it	Implement hypervisor-enforced tenant-level network isolation.	Network Admins
4	Reactive detection only	No automated alert fired. Detection happened after client complaints when encryption was already complete across both data centres	Deploy file integrity monitoring and behavioural EDR with ransomware rules on all VM hosts.	Admins / CISO

Table 29 – Improvement Recommendations

PART IV: Roles, Responsibilities and Communications

14.0 Roles and Responsibilities

The April 2026 incident confirmed that ambiguity in role authority is as operationally damaging as any technical failure. This section assigns unambiguous decision authority to each role before any incident occurs. Every action in Part III has a named owner. No action requires a committee decision.

14.1 IR Team Structure and Authority



Role	IR Phase(s)	Authority	Core Responsibility
CISO – IR Lead	All phases	Commander	Full command; all strategic decisions; executive briefings; incident closure; ransom payment authority
SOC Analyst	Detection → Recovery	Monitor	SIEM triage; IOC validation; threat intelligence; continuous monitoring throughout
System / Network Admins	Contain → Recovery	Technical Lead	Containment execution; forensic evidence; eradication; recovery; technical incident log
Legal Counsel	Detection → post-IR	Legal Authority	Regulatory compliance; notifications; law enforcement liaison; sanctions screening; ransom guidance
Customer Relations	Detection → Recovery	Comms Lead	Client notifications; SLA tracking; stakeholder management; media coordination
Executive / Board	Escalation points	Decision Authority	Ransom payment approval; board reporting; material risk decisions

Table 30 – IR Team Structure and Authority

14.2 RACI Matrix

R = Responsible. A = Accountable. C = Consulted. I = Informed.

Activity	CISO	SOC	Admins	Legal	Comms	Board
Incident Declaration	A/R	R	C	I	I	I
VM Isolation	A	C	R	–	–	–
Forensic Evidence	A	C	R	C	–	–
Client Notification	A	–	–	C	R	I
Regulatory Notification	A	–	–	R	C	C
Ransom Payment Decision	A	–	–	C	–	R
Recovery Sign-Off	A/R	C	R	–	C	I

Table 31 – RACI Matrix



14.3 Role Definitions

The CISO is the sole commander of the process, from activation to resolution, including the implementation of the IR plan, direction of activities, communication approval, and recovery efforts. Centralized leadership allows for swift decision-making in an environment where many clients are affected by delay and regulation.

SOC Analysts conduct detection and monitoring efforts. They handle validation of alerts, correlation of SIEM and EDR systems, investigation of IOCs, threat intelligence analysis, and continuous monitoring throughout the recovery effort.

System and Network Administrators implement all technical response efforts, from VM isolation on the hypervisor level, forensic evidence gathering, removal of credentials, rebuilding, and step-by-step restoration of the client's environment.

Legal counsel conducts all legal and regulatory aspects of the operation, including notification of regulatory bodies, sanctions checking prior to any ransom considerations, cooperation with law enforcement, and approval of external communication.

Customer Relations manages customer communications, including informing them of the attack, progress of the recovery effort, and successful return of services.

15.0 Communication Plan

15.1 Communication Chain

Audience	Responsible	Approval Required	Target Time
IR Team (internal)	CISO	None – out-of-band channel	Immediate
Executive Leadership	CISO	None	Within 1 hour
Board of Directors	CISO	None	Within 2 hours
Affected Clients (70+)	Customer Relations	CISO + Legal Counsel	Within 2 hours
Law Enforcement / CERT	Legal Counsel	CISO	Within 4 hours
Regulatory Bodies	Legal Counsel	CISO + Board	Per statutory deadline



Cyber Insurer	Legal Counsel	CISO	Within 24 hours
Media / Press	Comms + Legal	CISO + Board	Only if required

Table 32 – Communication Chain and Appro 1

15.2 Communication Templates

Template A – Internal IR Team Activation. Use phone or secure messaging. Do not use corporate email on potentially compromised systems.

INCIDENT ACTIVATION – [CRITICAL / HIGH]

Date / Time: [DATE] [TIME] (UTC) | Incident ID: [TICKET NUMBER]

Summary: Ransomware confirmed across [X] VM hosts in [Data Centre A / B / Both]. Estimated [X] client tenants affected. DarkCipher ransom note detected at [TIME].

Severity: **CRITICAL** | Declared by: [CISO Name]

Action Required: All IR Team members report to [out-of-band secure channel] immediately.

Out-of-Band Contact: [Phone Number]

Template B – Client Service Disruption Notice. Approved by CISO and Legal Counsel. Send within 2 hours of incident confirmation.



Subject: Important Notice – Service Disruption Affecting Your Hosted Resources

Dear [Client Name],

CloudNova Solutions is managing a security incident affecting access to your cloud-hosted resources. Our Incident Response Team identified the issue at [TIME] on [DATE] and is actively working to restore services.

We understand the operational impact. Restoring your services is our immediate priority. We will update you within [X] hours.

Your point of contact: [Name] | [Direct Phone] | [Email]

Customer Relations Team, CloudNova Solutions

Template C – Executive Summary Report for Board. Distribute within 24 hours of declaration. Update at each major milestone.

EXECUTIVE INCIDENT REPORT – [INCIDENT ID]

Date: [DATE] | Severity: **CRITICAL** | Status: [ACTIVE / CONTAINED / RECOVERING]

Summary: [2-3 sentences: what happened, when, current status]

Clients Affected: [X] | Systems Affected: [X] VMs | Estimated Downtime: [X] hours

Actions Taken: [Containment and eradication steps completed]

Next Steps: [Recovery timeline; regulatory notifications; restoration dates]

Decisions Required: [Ransom payment Y/N; major resource authorisation; public statement]

Template D – Regulatory Breach Notification. Completed by Legal Counsel; approved by CISO and Board. Submit within statutory deadline.

**DATA BREACH NOTIFICATION – [REGULATORY BODY NAME]**

Notifying Organisation: CloudNova Solutions | Date: [DATE]

Nature of Breach: Ransomware attack. Potential unauthorised access to client-hosted data. File encryption confirmed.

Date of Discovery: [DATE] | Estimated Date of Breach: [DATE]

Data Potentially Affected: Client business data hosted on affected VMs. Full inventory pending forensic analysis.

Approximate Data Subjects: [X – to be confirmed pending investigation]

Measures Taken: [Summary of containment, eradication, and notification actions]

Contact: [Legal Counsel Name] | [Phone] | [Email]

PART V: Evidence, Compliance and Metrics

16.0 Evidence Handling and Forensics

Evidence discipline determines whether the investigation can establish root cause, support prosecution, and withstand regulatory scrutiny. Every piece of forensic material must be handled consistently from the moment of collection.

16.1 Collection Standards

Standard	Requirement
Collection Sequence	Collect all logs before any remediation. Sources: hypervisors, monitoring tool, firewalls, DNS, proxy, email gateway, EDR, Active Directory.
Hashing Standard	All disk images and log archives must be SHA-256 hashed immediately after collection. Hash value recorded in Chain of Custody Register before item leaves collector.
Time Synchronisation	All systems NTP-synchronised. Flag and document any unsynchronised clocks. All timestamps in UTC.
Memory Imaging	Capture RAM from affected VMs before shutdown were safe. Memory preserves attacker processes, live connections, and potential decryption key material lost on reboot.



Disk Imaging	Use FTK Imager or dd. SHA-256 verify immediately after capture. Store two copies on independent media, separate from source and primary backup.
Storage	Encrypted, access-controlled forensic storage with full audit logging. Physical evidence in locked, access-controlled location.
Retention	Minimum seven years, or longer if required by law or ongoing legal proceedings.

Table 33 – Evidence Collection Standards 1

16.2 Chain of Custody Register

Ref #	Item Description	Collected By	Date/Time (UTC)	SHA-256 Hash	Storage Location
E-001	VM-HOST-01 Disk Image	[Admin Name]	[DATE] [TIME] UTC	[64-char hash value]	[Forensic NAS path]
E-002	[Item description]	[Collector]	[DATE / TIME]	[Hash value]	[Location]

Table 34 – Chain of Custody Register 1

17.0 Legal and Compliance Mapping

This playbook is built to meet or exceed the requirements listed below. Legal Counsel reviews the mapping at each quarterly review cycle.

Framework / Regulation	Requirement	Playbook Coverage
NIST SP 800-61r3 / CSF 2.0	Govern, Identify, Protect, Detect, Respond, Recover functions; playbook-based procedures	Parts III, IV, V — all lifecycle phases with phase banners and checklists
CISA Federal Playbooks (2024)	Lines of effort: asset response, threat response, intelligence support; standardised IR procedures	Sections 8-13; RACI matrix; communication chain; escalation decision tree
ISO/IEC 27035:2023	Plan, detect, assess, respond, learn; information security incident management	Sections 3-5, 7, 13-14; Lessons Learned template
SANS PICERL	Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned	Direct 1:1 mapping across Phases 1-7 in Part III



MITRE ATT&CK v15	Adversary TTP cataloguing; defensive control mapping	Section 5.1 (ATT&CK mapping); Section 8.2 (IOC table)
GDPR / Data Protection Law	72-hour breach notification to authority; individual notification without undue delay	Sections 15.0 and Template D
Cyber Insurance Policy	Timely insurer notification; cooperation with investigation	Section 15.1 communication chain; Legal Counsel role in Section 14
Client SLA Obligations	Uptime guarantees; breach notification timelines; restoration commitments	Sections 6.0, 12.0, and Template B in Section 15.2

Table 35 – Legal and Compliance Framework

18.0 Metrics and Reporting

Performance is measured against the targets below. Results are recorded for every incident and reported to the Board quarterly. The April 2026 DarkCipher event provides the CloudNova baseline. The objective is to improve against it with each subsequent incident.

Metric	Target	Apr 2026 Actual	Definition
Mean Time to Detect (MTTD)	≤ 15 min	[Record actual]	First observable ransomware behaviour to SIEM/EDR alert generation
Mean Time to Respond (MTTR)	≤ 30 min	[Record actual]	Detection to first containment action executed
Mean Time to Contain (MTTC)	≤ 6 hours	[Record actual]	IR activation to full host isolation across both data centers
Mean Time to Recover (MTTRec)	≤ 48 hours	[Record actual]	IR activation to first client tenant fully restored
Client Notification Time	≤ 2 hours	[Record actual]	Incident confirmed to initial client notification distributed
RCA Completion	≤ 5 business days	[Record actual]	Incident closure to completed RCA document delivered
Corrective Actions Closed	100%	[Track %]	Percentage of PIR improvement actions completed by assigned deadline

Table 36 – IR Performance Metrics and Ta 1



PART VI: Appendices

Appendix A: Tool Reference

Category	Tool / Platform	IR Phase(s)	Purpose
SIEM	[e.g., Splunk / Sentinel]	Detection → Recovery	Log correlation; alert generation; IOC matching; incident timeline
EDR	[e.g., Defender for Endpoint]	Detection → Eradication	Endpoint behavioural monitoring; ransomware detection; isolation
IDS / IPS	[Platform name]	Detection → Containment	Network analysis; C2 detection; lateral movement alerting; blocking
Vulnerability Scanner	[e.g., Nessus / Qualys]	Eradication → Recovery	Post-eradication patch validation; vulnerability rescan
Forensic Imaging	FTK Imager / dd	Containment → Eradication	Disk and memory acquisition; SHA-256 verification; chain of custody
Threat Intelligence	[TI Platform / Feed]	Detection → Eradication	DarkCipher IOC enrichment; C2 lookup; decryptor availability
ITSM / Ticketing	[e.g., ServiceNow / Jira]	All phases	Incident tracking; action assignment; evidence log; timeline
Secure Comms (OOB)	[Out-of-band channel]	All phases	IR Team coordination separate from potentially compromised systems

Table 37 – Approved IR Tool Reference 1

Appendix B: Contact List

Role	Name	Primary Contact	Backup Contact
CISO – IR Lead	[Name]	[Phone / Email]	[Name / Phone]
SOC Analyst (Lead)	[Name]	[Phone / Email]	[Name / Phone]
System Admin (Lead)	[Name]	[Phone / Email]	[Name / Phone]
Network Admin (Lead)	[Name]	[Phone / Email]	[Name / Phone]
Legal Counsel	[Name]	[Phone / Email]	[Name / Phone]
Customer Relations Lead	[Name]	[Phone / Email]	[Name / Phone]
DFIR Partner (24/7)	[Firm Name]	[24/7 Hotline]	[Account Manager]



Cyber Insurer	[Insurer Name]	[Claims Hotline]	[Policy No.]
National CERT	[CERT Name]	[Reporting Portal]	[Email]

Table 38 – Incident Response Contact Lis 1

Appendix C: Command Reference

Windows Incident Response Commands

Purpose	Command
Active network connections	netstat -ano
Running processes with PID	tasklist /v
Scheduled tasks	schtasks /query /fo LIST /v
Security event logs (last 50)	wevtutil qe Security /c:50 /f:text
Local user accounts	net user
Startup registry (current user)	reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run
Hash file (SHA-256)	certutil -hashfile [filename] SHA256
Disable network adapter	netsh interface set interface "[NIC Name]" admin=disabled

Table 39 – Windows Incident Response Com 1

Linux Incident Response Commands

Purpose	Command
Active connections	ss -tulnp
Processes by CPU	ps aux --sort=-%cpu head -20
Cron jobs	crontab -l && ls /etc/cron. *
Recently modified files	find / -mmin -60 -type f 2>/dev/null
SUID binaries	find / -perm -u=s -type f 2>/dev/null
Hash file (SHA-256)	sha256sum [filename]
Memory capture (LIME)	insmod lime.ko "path=/forensics/mem.dump format=lime"
Disk image (dd)	dd if=/dev/sda of=/forensics/disk.img bs=4M conv=sync,noerror

Table 40 – Linux Incident Response Comma 1

Appendix D: Glossary



Term	Definition
ATT&CK	MITRE framework cataloguing adversary tactics, techniques, and procedures. v15 used in this playbook.
C2	Command and control – attacker-controlled infrastructure directing malware post-compromise
CERT	Computer Emergency Response Team – national or sectoral cybersecurity coordination body
CISA	Cybersecurity and Infrastructure Security Agency – US federal cybersecurity authority. Playbooks published 2024.
CSF 2.0	NIST Cybersecurity Framework 2.0 (February 2024). Six functions: Govern, Identify, Protect, Detect, Respond, Recover.
DFIR	Digital Forensics and Incident Response – specialist discipline combining evidence analysis with active response
EDR	Endpoint Detection and Response – real-time endpoint monitoring and automated threat response
IaaS	Infrastructure-as-a-Service – cloud model providing virtualised compute, storage, and networking
IOC	Indicator of Compromise – observable artefact indicating a system may have been breached
MTTD / MTTR	Mean Time to Detect / Respond – key IR performance metrics
NIST SP 800-61r3	NIST Special Publication 800-61 Revision 3 (2024). Supersedes r2. Aligns incident response to CSF 2.0.
PIR	Post-Incident Review – structured debrief to drive measurable improvement after closure
RaaS	Ransomware-as-a-Service – criminal model where ransomware infrastructure is leased to affiliate operators
RCA	Root Cause Analysis – process identifying systemic failures that enabled an incident
SIEM	Security Information and Event Management – centralised log collection, correlation, and alerting
TLP	Traffic Light Protocol. TLP: RED = most restricted; named recipients only.
VM	Virtual Machine – software-based compute instance running on shared physical host infrastructure

Table 41 – Glossary of Terms 1